

2018-08-12 TRAFFIC ANALYSIS EXERCISE: ANSWERS

SPUTNIK HOUSE

www.malware-traffic-analysis.net/2018/08/12/2018-08-11-traffic-analysis-exercise.pcap.zip

Zip files are password-protected with the standard password. See the "about" page of my site if you don't know it.

The associated network segment:

- LAN segment: 192.168.1.0/24 (192.168.1.0 through 192.168.1.255)
- Broadcast address: 192.168.1.255
- Domain controller: 192.168.1.6 (Sputnikhouse-DC)
- Domain: sputnikhouse.org

SCENARIO:

You have alerts indicating a computer on the corporate network for **sputnikhouse.org** at 192.168.1.95 was infected. You have a pcap of traffic from that host during the general timeframe, and you also have a list of the alerts related to the infected. Finally, you have 3 emails with malware attachments. An attachment from one of those 3 emails infected this computer.

GOAL:

Figure out which email attachment infected this computer.

ANSWERS

- The file attachment named **PIC35793.iqy** from the email labeled **2018-08-12-traffic-analysis-exercise-email-1-UTC.eml** is the cause of this infection.

DETAILS:

As always, I recommend you set up Wireshark by changing the default column display according to the tutorials I've posted [here](#).

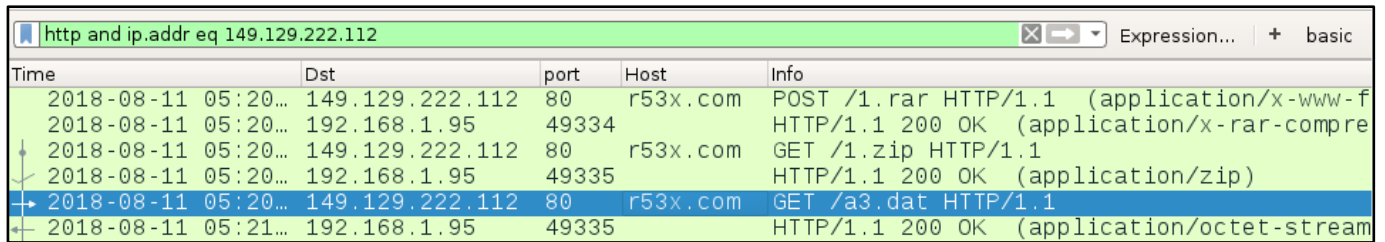
Your alert files are two text files with the alert data:

- 2018-08-12-traffic-analysis-exercise-Snort-alerts.txt
- 2018-08-12-traffic-analysis-exercise-Suricata-alerts.txt

Both alert files indicate there was a Windows executable or downloaded from 149.129.222.112 on 2018-08-11 at approximately 05:21 UTC. Use the following Wireshark filter for a closer look:

http and ip.addr eq 149.129.222.112

2018-08-12 TRAFFIC ANALYSIS EXERCISE: ANSWERS

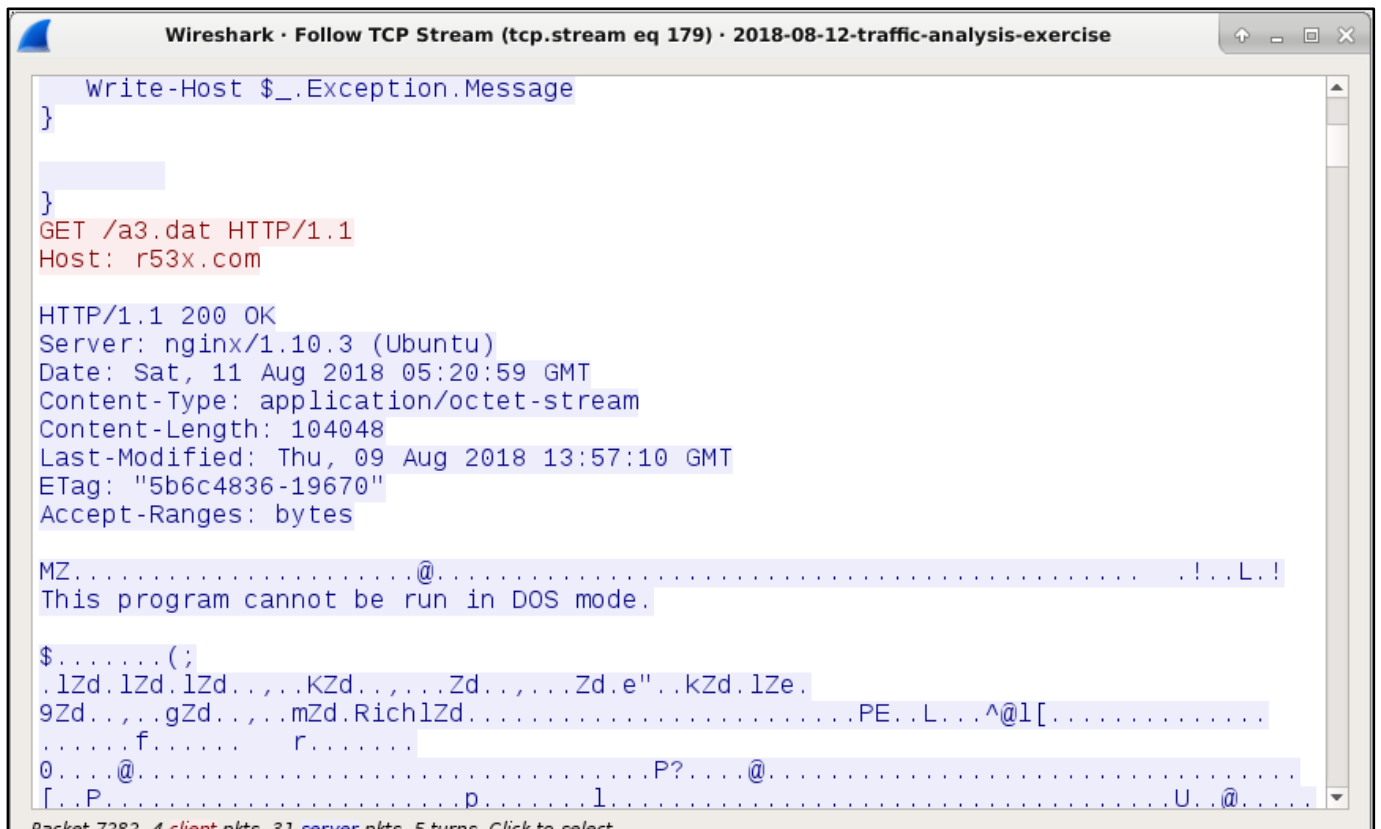


The screenshot shows a Wireshark packet capture with a filter 'http and ip.addr eq 149.129.222.112'. The packet list contains six entries. The first two are POST requests for '/1.rar' and '/1.zip'. The third is a GET request for '/1.zip'. The fourth is a 200 OK response for the '/1.zip' request. The fifth is a GET request for '/a3.dat'. The sixth is a 200 OK response for the '/a3.dat' request, with the content type 'application/octet-stream'.

Time	Dst	port	Host	Info
2018-08-11 05:20...	149.129.222.112	80	r53x.com	POST /1.rar HTTP/1.1 (application/x-www-f
2018-08-11 05:20...	192.168.1.95	49334		HTTP/1.1 200 OK (application/x-rar-compre
2018-08-11 05:20...	149.129.222.112	80	r53x.com	GET /1.zip HTTP/1.1
2018-08-11 05:20...	192.168.1.95	49335		HTTP/1.1 200 OK (application/zip)
2018-08-11 05:20...	149.129.222.112	80	r53x.com	GET /a3.dat HTTP/1.1
2018-08-11 05:21...	192.168.1.95	49335		HTTP/1.1 200 OK (application/octet-stream

Shown above: The HTTP requests to and responses from 149.129.222.112.

The first two HTTP requests for "1.rar" and "1.zip" do not return any RAR or ZIP archives. The last HTTP request returns a 200 OK with content labeled as "application/octet-stream." If you follow the TCP stream for the last HTTP request for "a3.dat," you'll find an executable file.



The screenshot shows the 'Follow TCP Stream' window for the TCP stream with ID 179. It displays the raw data of the HTTP request and response. The request is a GET for '/a3.dat' from 'r53x.com'. The response is a 200 OK from 'nginx/1.10.3 (Ubuntu)' with a 'Content-Type: application/octet-stream' and a 'Content-Length: 104048'. The response body contains a DOS batch file script that attempts to run a program and displays an error message.

```
Write-Host $_.Exception.Message
}
}
GET /a3.dat HTTP/1.1
Host: r53x.com

HTTP/1.1 200 OK
Server: nginx/1.10.3 (Ubuntu)
Date: Sat, 11 Aug 2018 05:20:59 GMT
Content-Type: application/octet-stream
Content-Length: 104048
Last-Modified: Thu, 09 Aug 2018 13:57:10 GMT
ETag: "5b6c4836-19670"
Accept-Ranges: bytes

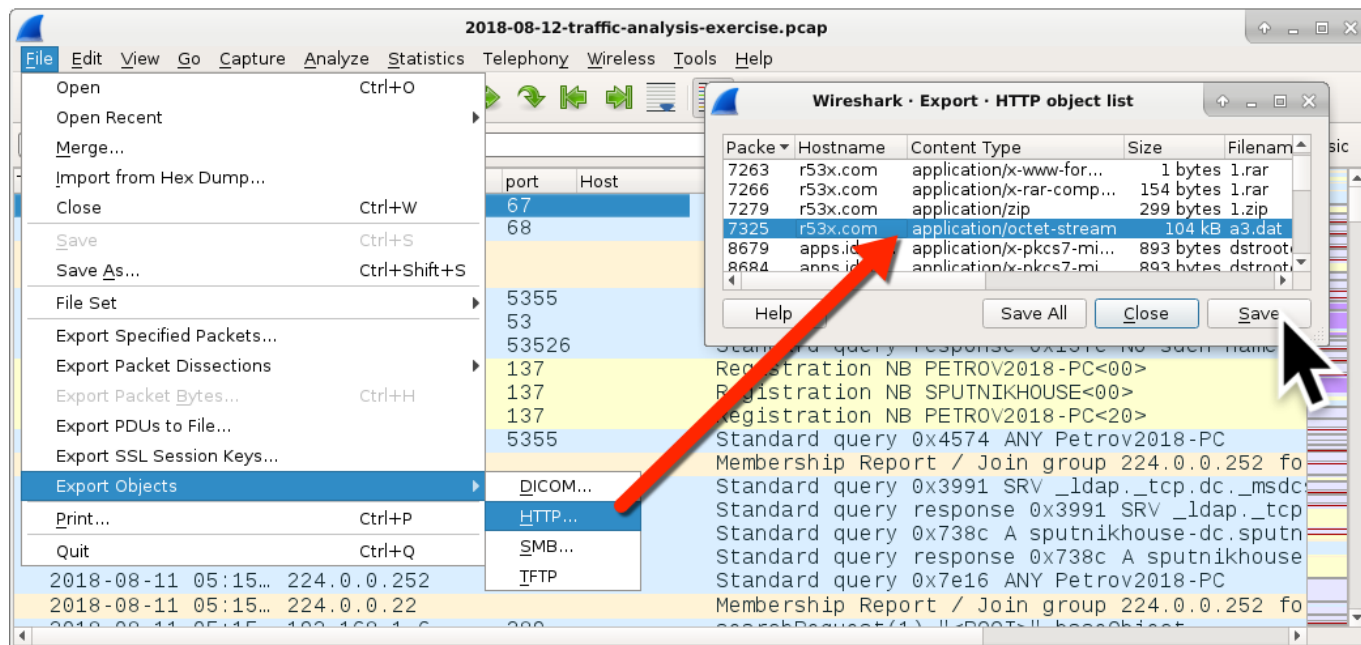
MZ.....@.....!..L.!
This program cannot be run in DOS mode.

$(;
.lZd.lZd.lZd...KZd...Zd...Zd.e"..kZd.lZe.
9Zd...gZd...mZd.RichlZd.....PE..L...^@1[.....
.....f.....r.....
0...@.....P?...@.....
[...P.....p.....l.....U...@.....
```

*Shown above: The HTTP requests for **a3.dat** returns an executable file.*

You can export the a3.dat file from the pcap by using File → Export Object → HTTP... After you've exported the file, you can check the file hash and search on the file hash on a service like VirusTotal.

2018-08-12 TRAFFIC ANALYSIS EXERCISE: ANSWERS



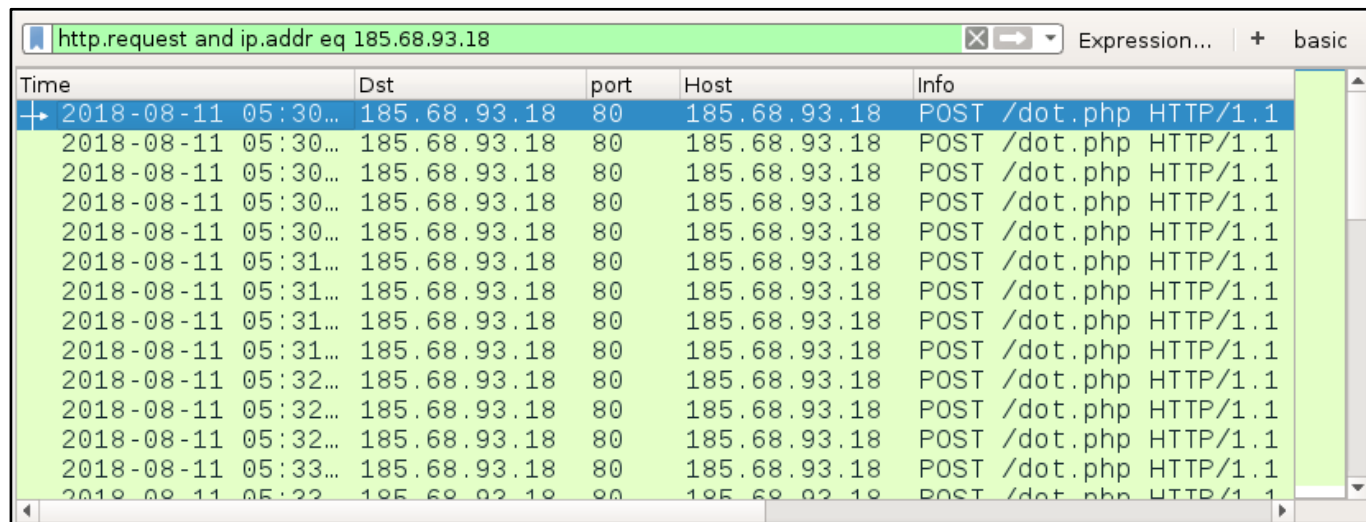
Shown above: Exporting the **a3.dat** file from Wireshark by exporting HTTP objects.

I've checked the malware in my lab environment, and it caused multiple lines of the following HTTP traffic over TCP port 80:

185.68.93.18 - POST /dot.php

This triggered the following alerts in the Suricata alert file:

- **ET INFO GENERIC SUSPICIOUS POST to Dotted Quad with Fake Browser 1**
- **ETPRO TROJAN Win32/Marap CnC Beacon**



Shown above: Filtering on the **Marap CNC Beacon** traffic on 185.68.93.18 in Wireshark.

2018-08-12 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Based on the alerts and the traffic in the pcap, it appears this machine is infected. Since today's exercise asks us to figure out which attachment from the three emails is responsible for this infection let's review the email attachments.

First email: 2018-08-12-traffic-analysis-exercise-email-1-UTC.eml

Attachment name: **PIC35793.iqy**

If you view the contents of **PIC35793.iqy** in a text editor, you'll find a URL for **<http://r53x.com/1.rar>** which is the first URL in this infection chain. This is probably the file that kicked off the infection.



*Shown above: Viewing **PIC35793.iqy** as a text file.*

IQY is a file extension for an "Internet query" used by Microsoft Excel. You have to click through some warnings to infect a vulnerable Windows host, but it can still be done. We've recently seen IQY files sent in malspam from the Necurs Botnet to push malware based on the Flawed Ammyy RAT. Follow [this link](#) for information on a recent example.

Whatever this is, I'm not sure it's the Flawed Ammyy RAT. Either way, we've accomplished the goal of this exercise.

Feel free to play around with malware from the other emails to see if they are somehow related, but I can assure you they are not related to this infection.

Using the Wireshark filter **Kerberos.CNameString**, we can find the Windows account name of **mikhail.petrov** and using the Wireshark filter **nbns**, we can find **Petrov2018-PC** as the host name for the computer on 192.168.1.95. Methods of determining this information can be found in previous traffic analysis exercises posted on this site.